

AI Governance: Balancing Innovation, Risk and ROI Under GDPR & the EU AI Act

Challenge — scaling AI without compromising reliability, compliance or ROI

I worked on AI governance at the intersection of **innovation, data privacy, model reliability and financial efficiency**. A key challenge was balancing the pressure to rapidly deploy multiple AI agents with the risks of technical debt, increasing cloud and token costs, hallucinations, data leakage and regulatory non-compliance under GDPR and the EU AI Act.

Rather than treating AI adoption as a race to deploy the largest number of use cases, I focused on identifying **where AI could deliver measurable value while keeping the cost of failure and compliance risk low**.

1. Speed vs. Caution

Rapid AI deployment can create a competitive advantage through faster time-to-market, but scaling too quickly can result in technical debt, incremental ROI, unnecessary cloud expenditure and increased data/privacy risks.

I addressed this by introducing a **risk-based approach to AI deployment**:

- Partnered with stakeholders to identify repetitive, high-volume tasks where AI could generate the greatest measurable value.
- Prioritised **lower-risk use cases** such as email drafting, document summarisation and basic code generation, where the benefits of automation were high and the cost of failure was relatively low.
- Used evidence from previous AI implementations, including **cost, accuracy, adoption and ROI metrics**, to build a financial case before scaling.
- Validated accuracy, cost and user adoption within smaller teams before expanding successful solutions across the organisation.
- Where a single agent could not meet the complexity of a workflow, worked with stakeholders to identify the requirements for a **multi-agent architecture with appropriate tools and controls**, rather than introducing unnecessary complexity upfront.

This created a decision framework around **speed × cost × reliability**, rather than simply maximising AI adoption.

2. Reliability vs. Automation

For financial and real-time information, fully automated AI responses introduced unacceptable hallucination risk. I therefore designed a **human-in-the-loop evaluation approach**, requiring human review for high-risk outputs involving real-time information or financial data.

This reduced hallucinations by **up to 96%**, while allowing lower-risk workflows to remain automated.

I also built a human evaluation pipeline that transformed PII and user logs into **anonymised evaluation datasets**, achieving **99% zero-data-leakage performance** and enabling systematic testing without unnecessarily exposing sensitive user information.

The principle was simple: **automate where failure is low-risk; introduce human oversight where accuracy, financial impact or privacy risk is high.**

3. Innovation vs. Governance

I also supported monthly AI training sessions focused on **prompt engineering and responsible AI usage**, helping employees improve query quality and increase effective participation.

However, I recognised that measuring success purely through prompt volume, usage or participation could create **vanity metrics**. Increased AI usage does not necessarily mean increased business value—and every additional token or model call can introduce incremental cost.

More importantly, employees could unintentionally enter client information, PII or confidential data into public AI tools, creating GDPR and AI governance risks.

I addressed this by embedding governance directly into enablement:

- Promoted the use of **private, internally controlled AI environments** rather than personal/public AI accounts for sensitive work.
- Incorporated clear **AI acceptance policies** into training, covering what information should never be entered into AI systems and when AI should not be used.
- Shifted measurement from simple usage metrics towards **quality, accuracy, productivity, adoption and business outcomes**.
- Encouraged **compressed, purposeful prompts** where they could achieve the same outcome with lower token consumption and cost.
- Prioritised responsible deployment where regulatory, privacy and reputational risks outweighed marginal productivity gains.

Outcome

The result was a more **risk-based and evidence-driven AI adoption model**: start small, prove value, establish governance, monitor outcomes and then scale.

Rather than launching dozens of experimental AI initiatives, I focused on solutions that could demonstrate a clear combination of **reliability, cost efficiency, user adoption and measurable productivity gains**—including workflows capable of saving **3–4 hours of work per day**.

The core lesson was that effective AI governance is not about slowing innovation. It is about **knowing where to move quickly, where to introduce controls, and where the expected ROI does not justify the risk.**